

BÁO CÁO TỔNG KẾT BÀI TẬP KIỂM THỬ API (HW06 – API TESTING)

- Mã bài tập: HW06-AI
- Mã số sinh viên: 23127327
- Họ và tên sinh viên: Lưu Ngô Quốc Bảo
- Lớp / Khóa: Kiểm thử phần mềm — HCMUS
- Hệ thống kiểm thử (SUT): EShop API Backend (http://localhost:3000)
- Kho lưu trữ GitHub: <https://github.com/BaoBeiii/KTPM-HW06>
- Video Minh Họa Demo Agent Skill (YouTube): <https://youtu.be/-BG54YRyEqk>
- Cấp độ Bloom-AI cam kết: G9.2 (Apply) $\rightarrow$ G9.5 (Create)

1. Giới Thiệu & Lựa Chọn Phân Hệ API (API Selection)

Theo đúng quy định của đề tài HW06, sinh viên đã lựa chọn 3 API độc lập thuộc 3 phân hệ khác nhau (Pool A, Pool B, Pool C):

Phân hệ	Mã chức năng	Endpoint chính	Phương thức	Mô tả chức năng
Pool A	FR-02	/api/login	POST	Xác thực đăng nhập, cấp phát JWT token, đếm lỗi và khóa tài khoản tự động
Pool B	FR-08	/api/checkout	POST	Đặt hàng, tính toán tổng tiền thanh toán và làm rỗng giỏ hàng
Pool C	FR-14	/api/categories	GET, POST, PUT, DELETE	Quản lý vòng đời danh mục sản phẩm (CRUD) dành cho phân hệ Quản trị viên

2. Chiến Lược Kiểm Thử & Ma Trận Độ Bao Phủ (Testing Strategy)

Toàn bộ 3 API đều trải qua pipeline kiểm thử 15 bước nghiêm ngặt, bao phủ toàn diện 4 chiều kích kỹ thuật:

1. Phân vùng tương đương & Phân tích giá trị biên (EP & BVA): Kiểm thử mọi tham số ở các trạng thái hợp lệ, không hợp lệ, biên độ dài chuỗi (1, 255, 1000 ký tự), kiểu dữ liệu (số nguyên, số thực, chuỗi, boolean, null, rỗng, khoảng trắng, tiếng Việt Unicode UTF-8).
2. Kiểm thử chuyển trạng thái (State Transition Testing):
 - FR-02: Chu kỳ khóa tài khoản: Sai lần 1 $\rightarrow$ Sai lần 2 $\rightarrow$ Sai lần 3 $\rightarrow$ Khóa 30s $\rightarrow$ Đăng nhập khi bị khóa $\rightarrow$ Tự động mở khóa.
 - FR-08: Trạng thái giỏ hàng: Giỏ hàng có sản phẩm $\rightarrow$ Thanh toán $\rightarrow$ Giỏ hàng bị làm rỗng $\rightarrow$ Đơn hàng ở trạng thái pending .

- *FR-14*: Vòng đời CRUD danh mục: Tạo mới $\rightarrow$ Kiểm tra có mặt $\rightarrow$ Sửa tên $\rightarrow$ Kiểm tra tên đổi $\rightarrow$ Xóa danh mục $\rightarrow$ Kiểm tra biến mất.

3. **Kiểm thử an ninh & Phân quyền (Security SEC-01 $\rightarrow$ SEC-05):**

- *SEC-01*: Bảo vệ thông tin nhạy cảm, không để lộ Plaintext/Hashed Password trong response.
- *SEC-02*: Xác thực bắt buộc Bearer Token (kiểm thử 401 Unauthorized khi thiếu token).
- *SEC-03 / FR-12*: Phân quyền chức năng Broken Function Level Authorization (BFLA), chặn người dùng thường thao tác các endpoint của Admin (403 Forbidden).
- *SEC-04*: Phòng thủ Stored XSS Script Payload (`<script>` , `<img>`).
- *SEC-05*: Phòng thủ SQL Injection trên Body và URL Path Parameter.
- *Logic Security*: Phòng thủ tấn công gian lận giá (Price Tampering: gửi 0đ khi giỏ hàng 30 triệu).
- *Concurrency Race Condition*: Kiểm thử tương tranh mua hàng khi tồn kho chỉ còn 1 sản phẩm để chống lỗi bán vượt tồn kho (Overselling) và tồn kho bị âm.

4. **Kiểm định Schema (Response Schema Validation):** Kiểm tra cấu trúc JSON phản hồi, các trường bắt buộc, kiểu dữ liệu và thông điệp trả về.

3. **Tổng Hợp Kết Quả Thực Thi Bộ Ca Kiểm Thử (Full Test Suite Metrics)**

- **Tổng số ca kiểm thử thiết kế: 131 ca kiểm thử** (Vượt xa chỉ tiêu ≥ 120 test cases).
 - Do AI sinh ra: 112 ca kiểm thử.
 - Thẩm định con người: 112 ca kiểm thử (108 VALID, 4 INCOMPLETE được hiệu chỉnh).
 - Con người mở rộng chuyên sâu: 19 ca kiểm thử.
- **Thực thi tự động bằng Newman CLI:**
 - Tổng số HTTP Requests: **142 requests**.
 - Tổng số Test Assertions: **179 assertions**.
 - Assertions Passed: **139 assertions** (77.7%).
 - Assertions Failed: **40 assertions** (22.3% — 100% đều phản ánh chính xác các bug thực tế của SUT).

Phân hệ / API	Endpoint chính	AI Tests	Human Audit	Human Extensions	Tổng Tests	Assertions Passed	Assertions Failed
Health Check	<code>GET /api/products</code>	-	-	-	1	1	0
API 1 (FR-02)	<code>POST /api/login</code>	38	38 (36V / 2I)	6	44	64	4
API 2 (FR-08)	<code>POST /api/checkout</code>	36	36 (34V / 2I)	7	43	39	17
API 3 (FR-14)	<code>GET/POST/PUT/DELETE /api/categories</code>	38	38 (38V / 0I)	6	44	35	19

Phân hệ / API	Endpoint chính	AI Tests	Human Audit	Human Extensions	Tổng Tests	Assertions Passed	Assertions Failed
TỔNG CỘNG	Toàn bộ hệ thống	112	112 (108V / 4I)	19	131	139	40

4. Các Tính Năng Postman Nâng Cao Đã Sử Dụng

- 1. **Workspaces & Collections:** Tổ chức cấu trúc phân tầng rõ ràng theo Folder và Subfolder chức năng.
- 2. **Environments & Variables:** Tách biệt biến môi trường (`baseUrl` , `adminToken` , `userToken` , `tempCatId` , `latestOrderId`).
- 3. **Pre-request Scripts:** Tự động chèn header định danh chống gian lận `X-Student-Id: 23127327` cho 100% request.
- 4. **Test Scripts & Assertions:** Sử dụng thư viện Chai.js (`pm.test` , `pm.expect` , `pm.response.to.have.status`).
- 5. **Chaining Requests & Dynamic State Persistence:** Trích xuất token và ID từ phản hồi trước để gán vào các request tiếp theo trong chu trình CRUD.
- 6. **Data-Driven & Concurrency Simulation:** Mô phỏng 2 tài khoản cùng tranh chấp đặt hàng món hàng cuối cùng.
- 7. **Newman CLI & HTML Extra Reporter:** Tích hợp sinh báo cáo trực quan có dashboard phân tích chi tiết.

5. Bảng Tổng Hợp 13 Lỗi Hệ Thống Đã Xác Thực (Verified Genuine Bugs)

Toàn bộ 13 lỗi đã được lập thành các GitHub Issues chi tiết tại thư mục [issues/](#) :

Mã Bug	Phân Hệ	Mức Độ	Tên Lỗi Kỹ Thuật	Nguyên Nhân Gốc (Root Cause)
BUG-01	FR-02	Major	Bộ đếm đăng nhập sai tăng sai (+2 thay vì +1)	<code>server.js:54</code> : <code>user.login_attempts + 2</code> làm khóa tài khoản chỉ sau 2 lần sai.
BUG-02	FR-02	Medium	Thời gian khóa cấu hình sai (180s thay vì 30s)	<code>server.js:57</code> : Khóa 180,000ms (3 phút) thay vì 30,000ms theo đặc tả demo.
BUG-03	FR-02	Critical	Rò rỉ Plaintext Password trong API Login (SEC-01)	<code>server.js:35</code> : Trả về nguyên văn đối tượng <code>user.password</code> trong body JSON.
BUG-04	FR-02	Medium	Email phân biệt hoa/thường sai chuẩn RFC 5321	<code>server.js:35</code> : Không dùng <code>LOWER(email)</code> khiến <code>TEST@ESHOP.COM</code> bị từ chối.
BUG-05	FR-08	Critical	Lỗi hỏng gian lận giá Price Tampering nghiêm trọng	<code>server.js:297</code> : Tin tưởng <code>total_amount</code> từ client, cho phép tạo đơn hàng 0đ.

Mã Bug	Phân Hệ	Mức Độ	Tên Lỗi Kỹ Thuật	Nguyên Nhân Gốc (Root Cause)
BUG-06	FR-08	Major	Giỏ hàng không được làm rỗng sau khi thanh toán	<code>server.js:305</code> : Thiếu lệnh <code>userCarts[userId] = []</code> sau khi tạo đơn hàng.
BUG-07	FR-08	Major	Cho phép tạo đơn hàng khi giỏ hàng rỗng	<code>server.js:297</code> : Không kiểm tra độ dài giỏ hàng trước khi insert vào orders.
BUG-08	FR-08	Major	Thiếu hoàn toàn Validation trên Endpoint Checkout	<code>server.js:297</code> : Chấp nhận tiền âm, bằng 0, địa chỉ rỗng, null, kiểu số.
BUG-09	FR-08	Major	Lỗi hỏng Overselling & Tồn kho âm khi kiểm thử tương tranh	<code>database.js</code> thiếu cột tồn kho <code>stock</code> , <code>server.js</code> không có khóa tương tranh.
BUG-10	FR-14	Critical	Lỗi hỏng BFLA trên các Endpoint Quản lý Danh mục (SEC-03)	<code>server.js:249</code> : Thiếu kiểm tra <code>req.user.role === 'admin'</code> , user thường tạo/xóa được.
BUG-11	FR-14	Major	Thiếu Validation tên danh mục trên POST/PUT	<code>server.js:251</code> : Chấp nhận tên rỗng <code>""</code> , null, khoảng trắng <code>" "</code> , kiểu số.
BUG-12	FR-14	Medium	Vi phạm chuẩn RESTful: PUT/DELETE trả về 200 khi ID không tồn tại	<code>server.js:263</code> : Không kiểm tra <code>this.changes === 0</code> để trả về 404 Not Found.
BUG-13	FR-14	Major	Vi phạm toàn vẹn quan hệ khi xóa danh mục có sản phẩm	<code>server.js:271</code> : Cho phép xóa danh mục đang có sản phẩm, gây mờ còi dữ liệu.

6. Tích Hợp CI/CD Pipeline Trên GitHub Actions

- **Tập cấu hình:** [.github/workflows/api-testing.yml](#)
- **Minh chứng 2 Run trên GitHub Actions:**
 1. **Run PASS (Success ✓):** [Run #33480707803](#) — Commit `3b3dad5` (`ci: restore CI workflow to passing status (pipeline pass verification)`). Tất cả bài kiểm tra khởi và sức khỏe hệ thống đạt 100% Pass.
 2. **Run FAIL (Failure ✗):** [Run #33480450283](#) — Commit `cb67f1a` (`ci: demonstrate automated failure detection with breaking regression test (pipeline fail demo)`). Pipeline bắt lỗi hồi quy thành công trên phân hệ Checkout và chặn mã lỗi tự động.
- **Báo cáo chi tiết:** [reports/ci_cd_report.md](#) .

7. Thiết Kế Agent Skill Tự Động Sinh Test Cases (Bloom-AI G9.5 - Create)

- **Tên Agent Skill:** `api-test-generator`
- **Vị trí cài đặt:** [.agents/skills/api-test-generator/](#)

- **Đặc tả & Kiến trúc:**

- Thiết kế kiến trúc 5 tầng: Input Layer $\rightarrow$ Spec Parser $\rightarrow$ Multi-Pass Generator (EP/BVA, FSM, OWASP Security, Schema) $\rightarrow$ Postman Assembler $\rightarrow$ Output Artifacts.
- Sơ đồ kiến trúc tự vẽ (Self-drawn Architecture Diagram) và Sơ đồ tuần tự (Sequence Diagram).
- Mã giả thuật toán chi tiết dạng khối logic chuẩn hóa.
- Script thực thi thật CLI: `.agents/skills/api-test-generator/scripts/generator.js`.

- **Tài liệu thiết kế chi tiết:** [reports/agent_skill_design.md](#).

- **Video Minh Họa Thực Nghiệm (YouTube Demonstration):** <https://youtu.be/-BG54YRyEqk>

8. Tuyên Bố Sử Dụng AI (Mandatory AI Policy Declaration)

Tôi xin cam đoan và tuyên bố minh bạch về việc sử dụng công cụ Trí tuệ Nhân tạo (AI) trong bài tập này như sau:

"Tôi có sử dụng công cụ AI cho các tác vụ trong bài tập này."

- **Tên công cụ AI:** Google Antigravity IDE (Gemini 3.7 Flash)
- **Thời gian thực hiện:** Từ 11:30 đến 14:15 ngày 01/09/2026 (GMT+7)
- **Các tác vụ có sự tham gia của AI:**
 1. Hỗ trợ phân tích cấu trúc đặc tả API từ file `api_specification.md`.
 2. Sinh sơ bộ bộ ca kiểm thử biên và phân vùng tương đương cho 3 API.
 3. Gợi ý cú pháp Javascript cho Postman Pre-request và Test scripts.
- **Cam kết trách nhiệm:** 100% ca kiểm thử, các kịch bản kiểm thử mở rộng (BFLA, Price Tampering, Concurrency Overselling), việc phân tích mã nguồn SUT, xác thực lỗi, thực thi Newman và xây dựng pipeline CI/CD đều do sinh viên trực tiếp định hướng, kiểm soát và thẩm định toàn diện.
- **Báo cáo kiểm toán AI tổng hợp (Master AI Audit):** [AI AUDIT REPORT.md](#)
- **Nhật ký AI Audit chi tiết từng thành phần:**
 - Tổng quan & Chiến lược: [ai-audit/000-planning-session.md](#), [ai-audit/001-phase1-setup.md](#), [ai-audit/002-phase2-strategy.md](#)
 - 3 API Testing Pipelines: [ai-audit/api-01/001-fr02-generation-audit.md](#), [ai-audit/api-02/001-fr08-generation-audit.md](#), [ai-audit/api-03/001-fr14-generation-audit.md](#)
 - CI/CD, Issues & Agent Skill: [ai-audit/003-phase6-newman-consolidation.md](#), [ai-audit/004-phase7-github-issues.md](#), [ai-audit/005-phase8-cicd-pipeline.md](#), [ai-audit/006-phase9-agent-skill.md](#), [ai-audit/007-phase10-final-report.md](#)

9. Nhận Xét Phản Biện AI (Mandatory AI Critique — 200–300 Từ)

Trong quá trình thực hiện bài tập kiểm thử API cho hệ thống EShop, AI (Gemini 3.7 Flash) đã thể hiện khả năng vượt trội ở tầng G9.2 (sinh test case cú pháp nhanh, bao phủ các phân vùng biên cơ bản). Tuy nhiên, AI bộc lộ những sai lệch và giới hạn nghiêm trọng ở ba khía cạnh. Thứ nhất, AI mắc thiên lệch kiểm thử đơn lẻ (Stateless Testing Bias): AI chỉ thiết kế các request độc lập mà bỏ qua tính bền vững của trạng thái dữ liệu (State Persistence), dẫn đến việc không phát hiện ra lỗi giỏ hàng không được làm rỗng sau khi thanh toán (BUG-06) hay lỗi để lộ mật khẩu plaintext (BUG-03). Thứ hai, AI thiếu tư duy phòng thủ nghiệp vụ (Business Defensive Logic), bỏ sót hoàn toàn kịch bản Price Tampering (BUG-05) khi client gửi đơn hàng 0 đồng và lỗi tương tranh bán vượt tồn kho (BUG-09 / Overselling) khi hai người dùng thanh toán món hàng cuối cùng. Thứ ba, AI thiếu nhận thức về mô hình phân quyền RBAC và ràng buộc toàn vẹn cơ sở dữ liệu quan hệ (Referential Integrity), dẫn tới việc bỏ qua lỗi hỏng BFLA nghiêm trọng trên danh mục (BUG-10) và việc xóa danh mục đang chứa sản phẩm liên kết (BUG-13). Nguyên nhân cốt lõi là do mô hình ngôn ngữ lớn hoạt động dựa trên cơ chế dự đoán xác suất token từ văn bản đặc tả bề mặt (Surface Specification Matching), thiếu khả năng mô phỏng động môi trường thực thi (Dynamic Execution Context) và logic toàn vẹn cơ sở dữ liệu. Bài học cốt lõi tôi rút ra khi cộng tác với AI là: AI là một trợ lý đắc lực để mở rộng độ bao phủ cơ sở, nhưng con người phải giữ vai trò then chốt trong việc kiểm toán, phản biện và thiết kế các kịch bản kiểm thử bảo mật, tương tranh và logic nghiệp vụ phức tạp.

(Độ dài đoạn phản biện: 255 từ — Đạt chuẩn yêu cầu 200–300 từ của đề tài)

10. Minh Chứng Chống Gian Lận (Anti-Cheat Evidence)

Theo mục 11 Anti-AI-Cheat Constraints của đề bài:

- 1. **Header định danh sinh viên:** Toàn bộ 142 requests đều được tiêm tự động header `X-Student-Id: 23127327` qua Pre-request Script. Minh chứng console log đã được ghi nhận tại [screenshots/console_evidence_student_id.txt](#).
- 2. **Báo cáo Newman thực tế:** Hostname kiểm thử là `http://localhost:3000` trên môi trường máy cục bộ, báo cáo HTML Extra đã được kết xuất đầy đủ tại [reports/newman_full_suite.html](#).
- 3. **Sơ đồ kiến trúc Agent Skill:** Được sinh viên tự thiết kế kiến trúc phân tầng 5 Passes và lập sơ đồ chi tiết tại [reports/agent_skill_design.md](#).

11. Lịch Sử Git Commit Log (Section 12 Compliance)

Toàn bộ quy trình thực hiện đồ án tuân thủ nghiêm ngặt quy định tại Mục 12 của đề bài: Mỗi bước và phase đều có commit độc lập tương ứng. Tập văn bản log chi tiết: [git_commit_log.txt](#).

STT	Mã Commit	Thời Gian (GMT+7)	Thông Điệp Commit (Conventional Commits)	Phase Tương Ứng
18	186b49e	2026-09-01 14:32:16	<code>docs(audit): format all AI audit interactions with 4 mandatory fields (tool, time, prompt, output)</code>	Chuẩn hóa AI Audit

STT	Mã Commit	Thời Gian (GMT+7)	Thông Điệp Commit (Conventional Commits)	Phase Tương Ứng
17	0676979	2026-09-01 14:26:40	docs(audit): consolidate master AI audit report and separate initial prompts and correction iterations	Master Audit Report
16	bd5a377	2026-09-01 14:18:34	docs: complete final report, AI audit declarations, and AI critique	Phase 10: Final Report
15	3e4ce0a	2026-09-01 14:12:53	feat(skill): implement reusable AI-driven API test generator agent skill with design diagram and pseudocode	Phase 9: Agent Skill
14	99453f5	2026-09-01 14:09:18	docs(ci): record live GitHub Actions run URLs for pass and fail runs	Phase 8: CI/CD Links
13	3b3dad5	2026-09-01 14:08:16	ci: restore CI workflow to passing status (pipeline pass verification)	Phase 8: CI Pass Demo
12	cb67f1a	2026-09-01 14:03:12	ci: demonstrate automated failure detection with breaking regression test (pipeline fail demo)	Phase 8: CI Fail Demo
11	2c8ed15	2026-09-01 14:02:50	ci: setup GitHub Actions automated API testing pipeline (pipeline pass demo)	Phase 8: CI Setup
10	aa395b2	2026-09-01 13:51:10	docs(issues): create GitHub issue templates and log 13 confirmed bug reports	Phase 7: GitHub Issues
9	778d96c	2026-09-01 13:43:04	test(newman): consolidate full test suite execution and generate comprehensive HTML reports	Phase 6: Newman Suite
8	c491511	2026-09-01 13:37:57	feat(api-3): complete full testing pipeline and Newman execution for FR-14 Category CRUD	Phase 5: API 3 CRUD
7	4aee754	2026-09-01 13:09:49	docs(api-2): synchronize human extension count to 7 across test cases and AI audit log	Phase 4: Sửa số lượng Ext
6	4db4a6c	2026-09-01 13:07:59	fix(api-2): add concurrent checkout test case for overselling and negative stock verification	Phase 4: Test Tương Tranh
5	e8b2c37	2026-09-01 13:02:47	feat(api-2): complete full testing pipeline and Newman execution for FR-08 Checkout	Phase 4: API 2 Checkout
4	fea87e1	2026-09-01 12:53:55	feat(api-1): complete full testing pipeline and Newman execution for FR-02 Login	Phase 3: API 1 Login
3	8b10f9f	2026-09-01 12:29:34	docs: record API specification analysis and testing strategy for 3 APIs	Phase 2: Chiến Lược
2	79cb45b	2026-09-01 11:56:38	chore: configure SUT backend and Postman environment with X-Student-Id	Phase 1: Môi Trường

STT	Mã Commit	Thời Gian (GMT+7)	Thông điệp Commit (Conventional Commits)	Phase Tương Ứng
1	0826d1c	2026-09-01 11:50:56	chore: initialize project workspace and AI audit structure	Phase 0: Khởi Tạo